A.D.E.P.T.: A Hybrid Framework for Correlating Command Hijacking and Traffic Fingerprinting Threats in Voice-Controlled IoT Platforms

Eugenio Cosimi, *2001071, Sapienza University of Rome,*
Guido Maria Nacca, *2212182, Sapienza University of Rome*

Abstract— Voice Personal Assistants (VPAs) like Amazon Alexa have become central hubs for controlling IoT devices, offering unprecedented convenience; however, there are significant security and privacy risks due to their open, third-party-driven ecosystems. Researchers have identified two separate but critical threat vectors: Command Hijacking and Voice Command Fingerprinting (VCF). The first involves malicious skills actively intercepting and manipulating user commands, while in the second, adversaries passively analyze encrypted network traffic to infer private user commands. These threats are usually analyzed separately, creating a major gap in understanding and defending against complex, multi-stage attacks. This text aims to fill that gap by proposing a novel hybrid security framework called A.D.E.P.T. (Adaptive Defense and Proactive Threat-Hunting), designed to be integrated into the VPA skill certification process; it proactively analyzes new skills by simultaneously performing dynamic behavioral analysis to detect hijacking attempts and network traffic fingerprinting to verify the skill's actual behavior. By correlating these two data streams, the framework can detect discrepancies that would be invisible if only one method were used, for example, a skill that claims to perform a benign action while its network traffic matches that of a malicious command. This approach aims to significantly enhance the security and privacy of the VPA ecosystem by creating a more resilient, proactive, and "context-aware" defense mechanism against both functional and informational threats.

Index Terms—IoT Security, Voice Personal Assistants, Amazon Alexa, Command Hijacking, Voice Command Fingerprinting, Network Traffic Analysis, Skill Certification, Hybrid Security Framework.

1 Introduction

The proliferation of Voice Personal Assistants (VPAs) has arguably altered 'human-computer' interaction, especially within smart home and IoT environments. Platforms like Amazon Alexa allow third-party developers to publish applications, or 'skills', to extend the product's functionality in virtually unlimited ways. Although this open model seeks innovation, it also creates a vast and complex attack surface, in this context, two distinct but complementary categories of risk have emerged, threatening both the functional integrity of the system and the privacy of its users. The core of the problem lies in the fact that two critical vulnerabilities, active command hijacking and passive traffic fingerprinting, have so far been treated as separate issues. In fact, there is currently no framework that considers the possibility of attackers combining these techniques or leveraging insights from one domain to defend against the other. A sophisticated adversary could use VCF for reconnaissance to identify high-value targets before launching a targeted and precise command hijacking attack. On the other hand, a security system that only monitors for behavioral anomalies might fail to detect a skill that appears to perform a benign action while its traffic patterns reveal it is exfiltrating data. A truly robust defense must be holistic, correlating what a skill claims to do with what its network traffic proves to be doing. Our work confronts this challenge directly by introducing A.D.E.P.T. (Adaptive Defense and Proactive Threat-Hunting), a hybrid security framework designed for integration into the VPA skill vetting pipeline (e.g., during the Amazon certification process). This project has both academic foundations, building upon existing research and a industrial orientation, aiming to provide a practical solution for VPA platform providers. A.D.E.P.T introduces a novel proactive layer that operates during certification phase, preventing malicious skills from ever reaching the marketplace. Due to its holistic design it is the first framework to defend against both functional hijacking and privacy leaking traffic patterns simultaneously and in its robustness by correlating two independent sources of information (behavioral logs and network traffic), it dramatically reduces the likelihood of being fooled by a sophisticated attacker. While an attacker may easily craft a fake audio response, it is significantly more difficult to forge a network traffic fingerprint that perfectly mimics a different command.

2 Background

To understand the context of this project, it is essential to detail the two primary threat vectors that currently affect Voice-Controlled IoT Platforms.

Functional Security Risk: Command Hijacking. As discussed in *Command Hijacking on Voice-Controlled IoT in the Amazon Alexa Platform*, the logic Alexa uses to select and invoke skills can be exploited by malicious developers, who

may publish skills specifically designed to intercept legitimate user commands intended for IoT devices. This can be achieved through various techniques, including the abuse of invocation names, the exploitation of skill category priorities, and the crafting of deceptive intents designed to manipulate Alexa's ranking algorithm. As a result, users risk losing control over their devices and may receive fake confirmations while a command is either ignored (Denial of Service) or, more dangerously, replaced with an unauthorized action (e.g., unlocking a door instead of turning off a light), undermining both the system's reliability and the user's physical security.

Information Privacy Risk: Voice Command Fingerprinting (VCF). As demonstrated in the paper *WhisperVoiceTrace: A Comprehensive Analysis of Voice Command Fingerprinting*, even when commands are executed correctly and communication is protected by encryption, a serious privacy risk remains. In fact, an adversary can apply traffic analysis techniques to the encrypted data exchanged between the voice assistant and the cloud servers. Through metadata analysis such as examining packet size, timing, and traffic direction machine learning models can fingerprint the network flow and infer the voice command issued by the user with over 90% accuracy. This passive threat can expose sensitive user information, such as daily routines, health concerns, shopping habits, and even the user's physical location, without ever breaking encryption or compromising the device itself.

3 Overview of the proposed approach

The A.D.E.P.T. (Adaptive Defense and Proactive Threat-Hunting) framework is founded on a simple but powerful principle: the claimed behaviour of a skill must match its verifiable network footprint, a principle achieved by correlating the outputs of two parallel analysis modules operating in a secure sandbox.

Framework Components: The **Dynamic Behavior Analyzer (DBA)**, inspired by IOTSKILLANALYZER (a dynamic and scalable tool designed to systematically test IoT skills), takes a skill submitted for certification and subjects it to a comprehensive suite of automated tests. The process simulates a wide range of voice commands, including both generic IoT commands (e.g., "turn off the lights") and those specific to the skill's declared functionality. It records the skill's explicit responses (e.g., "OK, the lights are off") and logs its interaction with a set of virtual IoT devices, culminating in a log of expected actions.

The **Network Traffic Fingerprinter (NTF)** which runs concurrently with the DBA, records all encrypted network traffic produced by the skill during the tests. In order to accurately fingerprint voice commands based only on network-level information, it employs a pretrained model based on WhiVo's architecture, which is a multi-stream convolutional neural network built to analyze encrypted traffic metadata by processing temporal features like packet sizes, directions, and timing through parallel CNN pipelines. A log of the actions that can be deduced from the network traffic analysis is the end result. For instance, the NTF may detect a traffic pattern that closely resembles a command to "unlock door" even if the skill's audio response is about lights.

It uses a set of crucial rules to flag skills: category mismatches, where a skill is declared under a low-risk category like "Q&A" but exhibits traffic patterns of high-risk smart home control; behavioral mismatches, where the DBA confirms an action (e.g., "I have closed the garage door") but the NTF detects no corresponding traffic; direct contradictions, where the DBA logs an expected action (e.g., light.turn_on) but the NTF infers a different and high-risk action (e.g., lock.unlock); and covert channel detection, where the declared action is performed correctly but the NTF finds unexplained traffic suggesting possible data exfiltration.

In the Decision Logic module, each skill is categorized based on the number and severity of anomalies found by the TCE, leading to one of three outcomes: Accepted, where skills free of any anomalies are approved automatically; Flagged for Manual Review, where skills with low confidence mismatches or minor inconsistencies are set aside for human inspection; Rejected, where skills exhibiting high confidence contradictions or known malicious patterns are automatically rejected.

Technical Implementation Plan: To ensure complete network and process isolation during testing, the A.D.E.P.T. framework is executed exclusively within a containerized sandbox environment, such as Docker, deployed on Amazon Web Services (AWS). This architecture allows the system to scale securely while maintaining strict control over each skill's execution context. The Dynamic Behavioral Analysis (DBA) module is implemented using the Alexa Skills Kit (ASK) Command Line Interface (CLI), a tool that enables direct interaction with Alexa's runtime environment through the terminal. The ASK CLI is integrated with a headless browser framework, such as Selenium, which facilitates the simulation of interactions with virtual devices. Voice commands are generated using a Text-to-Speech (TTS) engine, thereby creating a realistic emulation of user behavior.

A dedicated network interface within each sandbox is configured to capture outbound traffic using the `tcpdump` utility. This traffic is collected for processing by the Network Traffic Fingerprinter (NTF), which employs a Convolutional Neural Network (CNN) based on the WhiVo architecture; the model is then implemented using TensorFlow or PyTorch (open-source frameworks for machine learning) and is pre-trained on the WhisperVoiceTrace dataset. To improve its robustness, the model is further refined using malicious traffic samples collected during testing.

The Threat Correlation Engine (TCE), which represents the analytical core of A.D.E.P.T., is initially implemented as a Python-based rule engine. Its focus is on identifying high-priority inconsistencies between the DBA's behavioral logs and the NTF's traffic-derived inferences. These rules capture mismatches in declared vs. observed behavior and help flag

skills exhibiting anomalous or deceptive patterns. In the following iterations, the rule-based engine may be augmented with machine learning models to detect subtle correlations and previously unseen attack strategies.

SWOT Analysis

Strengths

Proactive Gatekeeper Model: Unlike reactive tools that analyze already published skills (such as IOTSKILLANALYZER), A.D.E.P.T. acts as a gatekeeper during the certification process, preventing threats from ever reaching the ecosystem and end users, shifting the security paradigm from "detection and response" to "prevention by design".

Synergistic Correlation: The real strength does not lie in the two analysis modules individually, but in their synergy. The Threat Correlation Engine (TCE) creates a cross validation system capable of identifying sophisticated attacks in which the declared behavior (e.g., a benign audio response) serves as a “smokescreen” for a malicious action (e.g., a traffic fingerprint corresponding to lock.unlock); this cross-domain correlation is its core innovation.

High-Fidelity Vetting: The use of two independent data streams, behavioral logs and network traces, drastically reduces the chance of error. A false positive from the behavioral analysis can be invalidated by clearly harmless network traffic, and vice versa. This dual verification approach enhances the robustness and reliability of the certification process, minimizing both false positives (benign skills wrongly rejected) and false negatives (malicious skills wrongly approved).

Weaknesses

Computational and Time Overhead: Running dual intensive analyses (dynamic simulation and deep learning-based traffic analysis) for each submitted skill is computationally expensive, this could slow down the VPA platform’s vetting process, introducing a potential bottleneck and forcing a trade-off between developer publishing speed and the level of guaranteed security.

Integration Complexity: Integrating A.D.E.P.T. into a large scale, proprietary certification pipeline like Amazon’s poses a significant engineering challenge, in fact it requires close cooperation with the platform provider, access to internal APIs, and assurance that the framework is scalable, maintainable, and resilient.

Dependence on Fingerprinting Model Accuracy: The effectiveness of the entire framework relies heavily on the performance of the NTF model (based on WhiVo). If the model is not adequately trained on a comprehensive and diverse dataset, or if new command types emerge with previously unseen traffic patterns, its ability to correctly identify actions may degrade, weakening the TCE’s correlation logic.

Potential for Sophisticated Evasion: A determined adversary may attempt to bypass analysis by designing a skill whose network traffic is deliberately ambiguous, placing it near the classification boundaries of the fingerprinting model to confuse the machine learning system (a form of adversarial attack).

Opportunities

Commercialization as a Security-as-a-Service (SaaS): A.D.E.P.T. has clear commercial potential, it could be developed as a SaaS solution offered to VPA platform providers (Amazon, Google, Apple) as an advanced certification service, ensuring a more secure and trustworthy ecosystem for users.

Setting a New Industry Standard: Successful adoption by a major market player could elevate A.D.E.P.T. to the status of a de facto standard for IoT skill security, pushing the entire industry toward higher levels of scrutiny and improve overall voice controlled IoT security.

Expansion to Other Ecosystems: The A.D.E.P.T framework could be adapted to protect other third party ecosystems, such as Google Assistant, Apple Siri/HomeKit, and emerging systems in automotive or industrial environments.

Creation of a Threat Intelligence Hub: The systematic analysis of thousands of skills would generate a unique and highly valuable dataset, containing correlated data on behavior and network patterns, this dataset could power a threat intelligence hub, used to train more advanced machine learning models and proactively detect emerging attack trends.

Threats

Adversarial Attacks on the NTF: Adversaries may focus not on evasion but on directly attacking the NTF module. Techniques like traffic padding (adding bogus data to alter packet size) or manipulating packet timing could “break” the fingerprints that the WhiVo model relies on, rendering it blind to certain actions.

Platform Evolution and API Breaking Changes: VPA platforms are constantly evolving. Updates by providers such as Amazon to communication protocols, encryption methods, or APIs may render the fingerprinting model or behavioral analysis obsolete, requiring ongoing maintenance and retraining to keep the framework effective.

Challenges from Evolving Attack Techniques: The framework, particularly in its initial version with a rule-based TCE, is effective against known threats; however, attackers constantly create new attack techniques that fall outside the predefined rules could bypass detection. There is the need to evolve the TCE toward a machine learning-based model, as suggested in the conclusions.

4 Evaluation

To validate the A.D.E.P.T. framework, our evaluation will address three primary research questions: **Effectiveness:** How accurately can A.D.E.P.T. identify and distinguish between benign skills, command hijacking attempts, and skills with mismatched behavioral and network footprints? **Performance Overhead:** What is the computational and time-based overhead introduced by the dual-analysis process into the skill certification pipeline? **Comparative Advantage:** Does the proposed hybrid correlation model provide a measurable improvement in detection rates and a reduction in false positives/negatives compared to using either behavioral

analysis or traffic fingerprinting alone? To answer these questions, we will follow a structured Work Breakdown Structure (WBS).

Phase 1: Research and System Design

1.1. Conduct an in-depth review of the IOTSKILLANALYZER and WhiVo architectures.
1.2. Finalize the A.D.E.P.T. framework design and establish correlation rules.
1.3. Set up the development and sandboxed testing environment.

Phase 2: Component Development

2.1. Develop the Dynamic Behavior Analyzer (DBA) module.
2.2. Implement the Network Traffic Fingerprinter (NTF) module.
2.3. Train and validate the WhiVo-based classification model using a curated dataset.
2.4. Develop the initial rule-based Threat Correlation Engine (TCE).

Phase 3: Integration and Testing

3.1. Integrate the DBA, NTF, and TCE into a unified analysis workflow.
3.2. Develop a comprehensive test suite of both benign and simulated malicious skills.
3.3. Perform unit testing and end-to-end system validation.

Phase 4: Experimental Evaluation and Analysis

4.1. Execute the full test suite through the A.D.E.P.T. framework.
4.2. Quantify key performance indicators (KPIs), including detection accuracy, performance overhead, and error rates.
4.3. Benchmark A.D.E.P.T.'s performance against standalone methods to quantify the advantage of the hybrid approach.

5 Related Work and Identified Gap

Our work builds directly upon two foundational studies that define the primary threat vectors in modern VPA ecosystems.

Command Hijacking on Voice-Controlled IoT in Amazon Alexa Platform. This work systematically identifies three concrete attack vectors that exploit Alexa's skill selection logic: Command-Invocation Confounding, Custom Command Attack, and Command-Intent Hijacking. The authors developed IOTSKILLANALYZER, a dynamic analysis tool that tests publicly available skills for these vulnerabilities. Their findings are alarming, more than 16% of the tested IoT skills exhibited critical vulnerabilities.
Limitation: IOTSKILLANALYZER is a reactive tool, it analyzes skills after they have been published but it does not prevent malicious skills from entering the ecosystem in the first place. Furthermore, its analysis is based solely on command-response behavior and does not inspect the underlying network traffic for covert activities.

WhisperVoiceTrace: A Comprehensive Analysis of Voice Command Fingerprinting. This paper introduces WhiVo, a state-of-the-art deep learning model for Voice Command Fingerprinting. The authors created a large-scale, realistic VCF dataset, accounting for user demographics and command types (static vs. dynamic). Their model demonstrates exceptionally high accuracy in identifying specific commands from encrypted traffic alone.
Limitation: This research focuses exclusively on the attack perspective. Although it's comprehensively demonstrating the severity of the privacy leak, it does not propose a concrete defensive mechanism that could leverage these fingerprinting capabilities. The techniques are presented for eavesdropping, not for system-level protection.

The Gap. The current state of the art provides powerful tools for either post-publication behavioral analysis (Ding et al.) or passive traffic analysis for privacy attacks (Jo et al.). There is no proposed solution that proactively integrates both approaches into a unified defense system within the skill certification process. A.D.E.P.T. is designed specifically to fill this critical gap.

6 Conclusions

The security and privacy of voice-controlled IoT platforms are at a critical juncture. While isolated research has successfully exposed severe vulnerabilities like command hijacking and traffic fingerprinting, defensive strategies have failed to keep pace. For this reason, the project proposes A.D.E.P.T., a paradigm shift from reactive, single-vector analysis to a proactive, holistic defense. Through the correlation of a skill's observable behavior with its underlying network footprint, A.D.E.P.T. can detect sophisticated attacks that are currently invisible. This project aims not only to build a functional prototype but also to provide a blueprint for the next generation of security systems needed to build and maintain user trust in the ever-expanding world of voice-controlled IoT. To ensure long-term resilience against ever-evolving threats, a primary future goal is to enhance the Threat Correlation Engine with machine learning; this would allow it to automatically learn and detect subtle, previously unseen attack patterns, moving beyond the limitations of a static rule set. On a broader scale, the A.D.E.P.T. concept holds significant potential for industry-wide impact, its core logic could be generalized and adapted for other VPA ecosystems, including Google Assistant and Apple's Siri, with the ultimate aim of establishing a new, cross-platform standard for skill security.

References

[1] W. Ding, S. Liao, L. Cheng, X. Mi, Z. Zhao, and H. Hu, "Command Hijacking in Voice-Controlled IoT on the Amazon Alexa Platform," in *Proc. ACM Asia Conf. on Computer and Communications Security (ASIA CCS)*, 2024.

[2] M. Jo, H. Kim, J. Hong, H. Kang, N. Mathews, and S. E. Oh, "WhisperVoiceTrace: A Comprehensive Analysis of Voice Command Fingerprinting," in *Proc. ACM Asia Conf. on Computer and Communications Security (ASIA CCS)*, 2024.

[3] Amazon Developer, “Alexa Skills Kit.” Available: https://developer.amazon.com/it-IT/alexa/alexa-skills-kit

[4] Amazon Web Services, “What is the AWS Command Line Interface (CLI)?” Available: https://aws.amazon.com/what-is/cli/

[5] IBM, “What are Convolutional Neural Networks?” *IBM Think Blog.* Available: https://www.ibm.com/think/topics/convolutional-neural-networks